

HIPAA COMPLIANCE POLICY

Dee Davis Inc.
Policy Number: DDI-HIPAA-001
Effective Date: March 29, 2026

1. Purpose & Scope

This HIPAA Compliance Policy establishes how Dee Davis Inc. protects the privacy and security of Protected Health Information (PHI) in accordance with the Health Insurance Portability and Accountability Act of 1996 (HIPAA), the HIPAA Privacy Rule (45 CFR Part 160 and Subpart E of Part 164), the HIPAA Security Rule (45 CFR Part 160 and Subparts A and C of Part 164), the HIPAA Breach Notification Rule (45 CFR Part 164 Subpart D), and applicable state law where more stringent.

The policy applies to all workforce members (employees, contractors, volunteers, and others under Dee Davis Inc.'s direct control) who handle PHI in the course of work for or on behalf of the organization. It applies to PHI the organization creates, receives, maintains, or transmits in electronic, paper, or oral form.

Where Dee Davis Inc. acts as a Business Associate, additional requirements in applicable Business Associate Agreements (BAAs) control if they are more specific than this policy; this policy must still be met at minimum.

2. Definitions

Protected Health Information (PHI) — Individually identifiable health information held or transmitted by a covered entity or business associate in any form or medium, except employment records held by a covered entity in its capacity as employer and certain other records excluded under HIPAA.

Business Associate Agreement (BAA) — A written contract required by HIPAA (45 CFR 164.504(e)) that describes permitted uses and disclosures of PHI by a Business Associate, requires safeguards, and sets terms for breach notification and subcontractor compliance.

Covered Entity — A health plan, health care clearinghouse, or health care provider who transmits any health information in electronic form in connection with a HIPAA-covered transaction (45 CFR 160.103).

Business Associate — A person or entity that creates, receives, maintains, or transmits PHI on behalf of a covered entity (or another business associate) for a function or activity regulated by HIPAA, including claims processing, data analysis, utilization review, billing, legal, actuarial, consulting, management, administrative, accreditation, or financial services (45 CFR 160.103). Dee Davis Inc. may act as a Business Associate when performing such services for a Covered Entity.

3. Designated Privacy Officer

Dieasha D. Davis serves as the Designated Privacy Officer for Dee Davis Inc. and is accountable for HIPAA privacy compliance, including policy oversight, workforce training coordination, complaint handling, and liaison with regulatory authorities as appropriate.

Title: President & CEO

Organization: Dee Davis Inc.

Address: 755 W. Big Beaver Rd., Suite 2020, Troy, Michigan 48084

Phone: 248.376.4550

Email: info@deedavis.biz

The Privacy Officer may delegate operational tasks to qualified personnel but retains accountability for the HIPAA program.

4. Permitted Uses and Disclosures of PHI

PHI may be used or disclosed only as permitted or required by HIPAA and applicable BAAs:

Treatment, Payment, and Health Care Operations (TPO) — As allowed under 45 CFR 164.506 when applicable to the relationship with the Covered Entity.

Authorization — Uses and disclosures not otherwise permitted require a valid individual authorization unless an exception applies.

Required by law — Disclosures required by statute, court order, or public health authority as permitted under 45 CFR 164.512.

Minimum Necessary — All uses, disclosures, and requests must comply with Section 6 (Minimum Necessary Standard).

Workforce members must not access, use, or disclose PHI for curiosity, personal reasons, or any purpose outside documented job duties.

5. Minimum Necessary Standard

When using, disclosing, or requesting PHI, Dee Davis Inc. must limit PHI to the minimum necessary to accomplish the intended purpose, except where the full record is required for treatment or as otherwise permitted by HIPAA (45 CFR 164.502(b), 164.514(d)).

Supervisors and the Privacy Officer must ensure role-based access: workforce members receive access only to the PHI reasonably necessary to perform assigned duties.

External requests for PHI must be reviewed to verify scope and legal basis before release.

6. Safeguards

Administrative Safeguards — Security management process; assigned security responsibility; workforce training; access management; contingency planning; evaluation; and Business Associate oversight, consistent with 45 CFR 164.308 where the Security Rule applies to electronic PHI.

Physical Safeguards — Facility access controls; workstation use and security; device and media controls for PHI in physical form.

Technical Safeguards — Access control; audit controls; integrity; person or entity authentication; and transmission security for electronic PHI (e-PHI) as applicable.

Dee Davis Inc. maintains reasonable and appropriate safeguards based on size, complexity, and the nature of PHI handled.

7. Employee Training Requirements

All workforce members with access to PHI must receive HIPAA privacy and security training at hire and at least annually thereafter, or sooner when material changes to policies or regulations occur.

Training must cover: this policy; PHI definitions; permitted uses; minimum necessary; safeguards; reporting incidents; and sanctions for violations.

Documentation of training (attendance, date, topic) must be retained as required by the organization's compliance program.

8. Business Associate Agreement Requirements

Before a vendor or subcontractor may create, receive, maintain, or transmit PHI on behalf of Dee Davis Inc. (as a Business Associate or subcontractor), a written BAA (or subcontractor agreement incorporating BAA terms) must be executed in accordance with 45 CFR 164.504(e).

The BAA must specify permitted uses and disclosures; require safeguards; require breach notification to Dee Davis Inc.; and require flow-down obligations to subcontractors as required.

No PHI may be shared with a new Business Associate until the BAA is fully executed, except as allowed by law in limited circumstances.

9. Breach Notification Procedures (60-Day Rule and Related Requirements)

A breach is the acquisition, access, use, or disclosure of PHI in a manner not permitted under the Privacy Rule that compromises security or privacy, subject to the risk assessment and exceptions in 45 CFR 164.402–164.406.

Discovery and internal escalation — Any workforce member who suspects a breach must notify the Privacy Officer immediately (same-day if feasible).

Risk assessment — The Privacy Officer (or designee) conducts a documented risk assessment to determine if unsecured PHI was compromised and whether notification is required.

Notification to the Covered Entity — If Dee Davis Inc. is a Business Associate, notification to the relevant Covered Entity must be without unreasonable delay and no later than 60 calendar days after discovery of the breach (45 CFR 164.410), unless the BAA specifies an earlier timeframe — the stricter timeline applies.

HHS and individuals — Covered Entity clients are responsible for notifying affected individuals and, when required, the Secretary of HHS and media; Dee Davis Inc. will cooperate fully and provide information necessary for those notifications per the BAA.

Documentation — Breach documentation (assessment, facts, mitigation) must be retained for at least six years as required by HIPAA.

10. Member / Individual Rights

To the extent Dee Davis Inc. maintains PHI on behalf of a Covered Entity, individual rights (access, amendment, accounting of disclosures, restrictions, confidential communications) are primarily exercised through the Covered Entity; Dee Davis Inc. will forward requests promptly to the Covered Entity and assist as required by the BAA.

If Dee Davis Inc. receives a request directly, the Privacy Officer will acknowledge receipt, coordinate with the Covered Entity within required timeframes, and document the response path.

11. Complaint Procedures

Individuals or workforce members may file privacy complaints in writing to the Privacy Officer at info@deedavis.biz or 755 W. Big Beaver Rd., Suite 200, Troy, Michigan 48084.

Complaints will be acknowledged; investigated reasonably; and documented. No retaliation is permitted against good-faith reporting.

Individuals may also file complaints with the U.S. Department of Health and Human Services, Office for Civil Rights (OCR). Contact information for OCR is available at www.hhs.gov/ocr/privacy/hipaa/complaints/.

12. Sanctions for Non-Compliance

Violations of this policy or HIPAA may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where appropriate.

Intentional misuse of PHI, snooping, or failure to report suspected breaches may result in immediate escalation.

Dee Davis Inc. may also be subject to civil and criminal penalties under HIPAA and related law for non-compliance.

13. Policy Review

This policy will be reviewed at least annually and updated when laws, regulations, or business operations change materially.

ACKNOWLEDGED AND ADOPTED:

Dieasha D. Davis
President & CEO
Dee Davis Inc.